

Warsaw, November 23, 2022

Decision

DS.523.1436.2022

Based on Article 104 § 1 of the Act of June 14, 1960, the Code of Administrative Procedure (consolidated text: Journal of Laws of 2022, item 2000) in conjunction with Article 7 § 1 of the Act of May 10, 2018, on the Protection of Personal Data (consolidated text: Journal of Laws of 2019, item 1781) and based on Article 5 § 1 letters a and b, Article 9 § 1 and 2, and Article 58 § 2 letter b of the Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016, on the protection of natural persons in relation to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (Official Journal of the EU L 119 of May 4, 2016, p. 1, Official Journal of the EU L 127 of May 23, 2018, p. 2, and Official Journal of the EU L 74 of March 4, 2021, p. 35), after conducting administrative proceedings regarding the complaint of Ms. K. G. (street (...) W.), concerning irregularities in the processing of her personal data by W. based in W., consisting of Ms. (...) K. P. gaining access to her personal data processed on Platform U., the President of the Personal Data Protection Office:

- 1) issues a reprimand to W. based in W. for violating Article 9 § 1 in conjunction with Article 5 § 1 letters a and b of the GDPR, consisting of gaining access on (...) January 2022 to the personal data of Ms. K. G. (street (...) W.) without legal basis, obtained from Platform U. based in W., using the internal IT system A.;
- 2) in other respects, denies the request.

Justification

A complaint was submitted to the Personal Data Protection Office by Ms. K. G. (street (...) W.), hereinafter referred to as the Complainant, represented by Ms. A. S. (street (...) P.), regarding irregularities in the processing of her personal data by W. based in W., hereinafter referred to as W., consisting of Ms. (...) K. P. gaining access to her personal data processed on Platform U.

In the complaint, the Complainant's representative indicated that the Complainant received two messages from the Portal U., which indicate that on (...) January 2022, doctor K. P. gained access to the Complainant's data, which was not concluded with the issuance of a medical certificate or its cancellation. The complaint emphasized that the Complainant was not a patient of doctor K. P., yet she used the Complainant's PESEL number and consequently gained access to the Complainant's personal data through P. The Complainant does not rule out that (...) K. P. gained access to her personal data through the medical data management system used by the employer – A.

In light of the above, the Complainant requested the deprivation of the aforementioned data processor/data administrator of the right to process her personal data.

During the ongoing administrative proceedings, the President of the Personal Data Protection Office obtained clarifications regarding the circumstances of the case and established the following factual state:

The Complainant received two notifications from P. stating, "On 2022-01-(...) doctor K. P. (license number (...)) gained access to your data, not concluded with the issuance of a medical certificate or its cancellation" (evidence: copies of the aforementioned messages).

(...) K. P. was not and is not the treating physician of the Complainant (evidence: complaint from (...) February 2022).

The Complainant is employed at W. in (...) in the position of (...). Ms. (...) K. P. is (...) and the direct supervisor of the Complainant, responsible for organizing work and ensuring the continuity of healthcare services provided in this department. Ms. K. P. was granted authorization to process personal data, including in IT systems, of employees (...) necessary to ensure the continuity of the department's operations (evidence: clarifications from W. of (...) March 2022, copy of authorization to process personal data no. (...)).

As explained by W., quote: "Ms. (...) K. P. in order to verify the work schedules of her subordinate staff, reviewed the work schedule of the Complainant in the internal system X., identifying discrepancies between the report and that schedule. She used the functionality of the IT system A. implemented in

W., which provides access to the list of sick leaves. As a result of the verification conducted by Ms. (...) K. P., the IT system A. caused an automatic connection to the Complainant's ZUS account, and consequently, the Complainant received a relevant message from the ZUS account, which is a correct functionality of these systems (...) the IT system A. is a medical system that, due to the electronic nature of actions in the medical area, has the ability to query other systems, including national ones (e.g., the ZUS system) for data of the insured person. The sharing of data between systems mostly occurs with the login and password of the user authorized to perform this action in system A. (e.g., a doctor). This means that in the case of a user of the internal system A., the ZUS system will record the query made by the user's system A. – that is, for example, by a doctor. Considering the above, the ZUS portal will not record the action of updating the list of sick leaves issued to the Patient, only access to the data by a user authorized by ZUS will be recorded” (evidence: clarifications from W. of (...) March 2022).

W. unequivocally stated that (...) K. P. did not gain access to the account of P. the Complainant (evidence: W.'s explanations from (...) March 2022). In connection with the complaint made by the Complainant regarding the violation of her personal data, W. conducted an explanatory procedure, during which it was established that (...) K. P. only used the A. IT system. In W.'s assessment, the aforementioned did not familiarize herself with data of a special category, but only processed personal data referred to in Article 22¹ of the Labor Code (evidence: W.'s explanations from (...) March 2022). W. also stated that the supervisor of Ms. (...) K. P., (...) Mr. (...) P. K. drew her attention to the inappropriate method of verifying the Complainant's sick leave, while simultaneously issuing a recommendation that the verification of sick leave periods or other reasons for absence should be conducted through the HR Department of W. (evidence: W.'s explanations from (...) March 2022). W. issued a communication for staff with access to the A. IT system regarding the principles of its proper use, including criminal and civil liability for violating statutory obligations (evidence: W.'s explanations from (...) March 2022, copy of the aforementioned communication).

After reviewing all the evidence collected in the case, the President of the Personal Data Protection Office considered the following.

First of all, it should be noted that "personal data" within the meaning of Article 4 point 1 of the Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016, on the protection of natural persons in relation to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (OJ EU L 119 of 4.05.2016, p. 1, OJ EU L 127 of 23.05.2018, p. 2, and OJ EU L 74 of 4.03.2021, p. 35), hereinafter referred to as GDPR, is understood as information about an identified or identifiable natural person ("data subject"); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier such as a name, identification number, location data, online identifier, or one or more specific factors characteristic of the physical, physiological, genetic, mental, economic, cultural, or social identity of that natural person. On the other hand, "data processing" means an operation or set of operations performed on personal data or sets of personal data, whether or not by automated means, such as collection, recording, organization, structuring, storage, adaptation or alteration, retrieval, consultation, use, disclosure by transmission, dissemination or otherwise making available, alignment or combination, restriction, erasure, or destruction (Article 4 point 2 GDPR).

According to Recital 35 of GDPR, health-related personal data includes all data concerning the health status of the data subject, revealing information about the past, present, or future physical or mental health status of the data subject. Such data includes information about a given natural person collected during their registration for healthcare services or during the provision of healthcare services, as defined by the Directive of the European Parliament and of the Council 2011/24/EU; a number, symbol, or identifier assigned to a given natural person for the purpose of uniquely identifying that natural person for health purposes; information derived from laboratory tests or medical examinations of body parts or bodily fluids, including genetic data and biological samples; and any information, for example, about illness, disability, disease risk, medical history, clinical treatment, or physiological or biomedical condition of the data subject, regardless of its source, which may be, for example, a doctor

or other healthcare worker, a hospital, a medical device, or an in vitro diagnostic test. According to Article 4 point 15 GDPR, health data means personal data related to the physical or mental health of a natural person – including the provision of health services – revealing information about that person's health status.

In the opinion of the President of the Personal Data Protection Office, personal data concerning absence from work due to sick leave falls within the scope of special categories of personal data, as it reveals information about the health status of the employee, i.e., the reason related to that status preventing the employee from performing work. The processing of such data is regulated in Article 9 GDPR, which generally prohibits the processing of special categories of data (paragraph 1), unless one of the conditions enumerated in Article 9 paragraph 2 GDPR is met. The processing of such data is lawful, among other things, when the processing is necessary for fulfilling obligations and exercising specific rights by the controller or the data subject in the field of employment law, social security, and social protection, provided that it is permitted by Union law or the law of a Member State, or a collective agreement under the law of a Member State providing for appropriate safeguards for the fundamental rights and interests of the data subject (Article 9 paragraph 2 letter b GDPR) and when the processing is necessary for health care or occupational medicine, for assessing the employee's ability to work, for medical diagnosis, for the provision of health care or social security, for treatment, or for the management of health care or social security systems and services based on Union law or the law of a Member State or in accordance with an agreement.

with a healthcare worker and subject to the conditions and safeguards referred to in paragraph 3 (Article 9(2)(h) of the GDPR). At the same time, the process of personal data processing must comply with the principles established in Article 5(1) of the GDPR. According to Article 5(1) of the GDPR, personal data must be processed, among other things, lawfully (lit. a); collected for specific, explicit, and legitimate purposes and not further processed in a manner incompatible with those purposes (lit. b); adequate, relevant, and limited to what is necessary for the purposes for which they are processed (lit. c); and processed in a manner that ensures appropriate security of personal data, including protection against unauthorized or unlawful processing, using appropriate technical or organizational measures (lit. f). According to Article 5(2) of the GDPR, the controller is responsible for compliance with the provisions of paragraph 1 and must be able to demonstrate such compliance.

Based on Article 54(1) of the Act of June 25, 1999 on cash benefits from social insurance in the event of sickness and maternity (Journal of Laws of 2022, item 1732), hereinafter referred to as the benefit act, the Social Insurance Institution (ZUS) authorizes the issuance of medical certificates of temporary incapacity for work due to illness, hospitalization, or stay in another healthcare facility providing stationary and round-the-clock health services, by a doctor, dentist, paramedic, or senior paramedic, upon submission, in the form specified in this provision, of a declaration that they undertake to comply with the principles of determining temporary incapacity for work and fulfilling the obligations arising from the provisions of the act and the regulations on the protection of personal data.

According to Article 55a(2) of the benefit act, ZUS provides, free of charge, the data collected under the Act on the Social Insurance System to the issuer of the medical certificate on their information profile for the purpose of issuing the medical certificate, including: the Central Register of Insured Persons (first name, surname, date of birth, and address of residence of the insured), the Central Register of Contribution Payers (the abbreviated name and NIP or PESEL number or series and number of the passport of the contribution payer, if there is no obligation to use NIP and no PESEL number has been assigned), as well as information about previous medical certificates issued to the insured, collected in the register referred to in Article 55b(1) of the benefit act and about certificates referred to in Article 59(8) of the benefit act. According to Article 55a(3) of the aforementioned act, ZUS provides the data and information mentioned above after the issuer of the medical certificate provides the PESEL number of the insured or the series and number of the passport if the insured has not been assigned a PESEL number.

In this case, the Complainant alleged that (...) K. P., as her direct supervisor, gained unauthorized access to her personal data processed on the U Platform. During the proceedings, it was established

that the aforementioned individual, in order to verify the work schedules of her subordinate staff, utilized the functionality of the implemented IT system A. in W., which provides access to the list of medical leave. (...) K. P. did not log directly into the Z. system for this purpose; however, the A. system caused an automatic connection to the ZUS account of the Complainant. From the above, it follows that (...) K. P. gained access to the personal data of the Complainant processed on P., regardless of the method of logging in. This fact is unequivocally confirmed by the information generated by ZUS, which the Complainant received.

The evidence gathered in this case indicates that (...) K. P. did not obtain information regarding the Complainant from A. for purposes related to the provision of medical services, as she was not the Complainant's doctor. It should be noted that there are no provisions that would legalize the acquisition of access to personal data by doctors through medical systems for purposes other than providing medical services. There are also no provisions that would legalize the acquisition of access to personal data by doctors through P. for purposes other than issuing, canceling, or correcting a medical certificate. It should be emphasized that personal data processed in medical systems pertains to the health status of patients, thus such data should be subject to special protection. W., as the administrator, must have full control over the data processing process to ensure compliance with legal provisions. They must also have full knowledge of the entire data processing process and must verify the behavior of employees in terms of their compliance with the principles of personal data protection. The President of the Personal Data Protection Office shares the current position under the GDPR of the Supreme Administrative Court in Warsaw expressed in the judgment of April 4, 2003 (II SA 2935/02), that the administrator is responsible for the actions of its employees regarding violations of the Act of August 29, 1997 on the protection of personal data.

In light of the above, in the opinion of the President of the Personal Data Protection Office, in this case, there was unlawful processing of the Complainant's personal data obtained from the U Platform based in W., using the internal IT system A. This means that in the analyzed case, there was a violation of Article 9(1) in conjunction with Article 5(1)(a) and (b) of the GDPR. Based on Article 58(2) of the GDPR, the President of the Personal Data Protection Office has corrective powers, including issuing warnings to the administrator or processor in the event of violations of the provisions of this regulation by processing operations (lit. b). In light of the above, the President of the Personal Data Protection Office recognized,

that in the circumstances of this case, it is appropriate to apply a warning to W. for the aforementioned established violation of the provisions on the protection of personal data.

Regarding the request of the Complainant to cease the processing of her personal data by the administrator, it should be noted that this is not possible. As established during the proceedings, the Complainant has an employment relationship with W. The existence of an employment relationship generates a number of obligations on the part of the employer related to documenting the employee's work, including the right to remuneration during periods of incapacity for work. According to § 3 point 1 of the Regulation of the Minister of Labor and Social Policy of May 15, 1996, on the justification of absence from work and granting employees leave from work (i.e., Journal of Laws of 2014, item 1632), the documents justifying absence from work include, among others, a medical certificate referred to in Article 55 paragraph 1 of the Act of June 25, 1999, on cash benefits from social insurance in the event of sickness and maternity.

In light of the above, W., as the employer of the Complainant, is obliged to process the Complainant's personal data concerning the medical certificates issued to her, which falls under the premise resulting from Article 9 paragraph 2 letter b of the GDPR. Regarding the processing of the Complainant's personal data in the aforementioned scope by (...) K. P., it should be noted that the latter has been authorized by the administrator to process the personal data of employees (...) necessary to ensure the continuity of the department's operations, based on Article 29 of the GDPR, according to which the data processor and any person acting on behalf of the administrator or the data processor and having access to personal data may only process it on the instructions of the administrator, unless required by Union law or the law of a Member State.

It should also be noted that according to Article 58 paragraph 1 of the Benefit Act, the Social Insurance Institution provides the medical certificate free of charge to the payer of contributions on the information profile of the payer of contributions, without the information referred to in Article 55 paragraph 3 point 9, no later than the day following the day of receipt of the medical certificate. Therefore, the scope of data obtained by the payer of contributions is narrower and does not include the statistical number of the insured's disease established according to the International Statistical Classification of Diseases and Related Health Problems. Furthermore, the payer of contributions does not obtain access to information about previous medical certificates issued to the insured when there was no employment relationship with the insured.

For this reason, in this regard, the President of the Personal Data Protection Office refused to grant the Complainant's request, as it is not possible to issue a general prohibition on the processing of the Complainant's personal data concerning medical certificates by W.

In this factual and legal situation, the President of the Personal Data Protection Office decided as stated in the ruling.

INSTRUCTION The decision is final. Based on Article 7 paragraph 2 of the Act of May 10, 2018, on the protection of personal data (Journal of Laws of 2019, item 1781) and in connection with Article 13 § 2, Article 53 § 1, and Article 54 of the Act of August 30, 2002, on proceedings before administrative courts (Journal of Laws 2022, item 329, as amended), the party has the right to file a complaint with the Provincial Administrative Court in Warsaw within 30 days from the date of delivery of this decision, through the President of the Personal Data Protection Office (address: Personal Data Protection Office, ul. Stawki 2, 00 – 193 Warsaw). The fee for the complaint is 200 zlotys. The party has the right to apply for legal aid, including exemption from court costs.

Print article

Metadata

Providing entity:

Complaints Department

Information created by:

Jan Nowak

2022-11-23

Information entered by:

Łukasz Kaczmarczyk

2023-09-21 14:46:34

Last modified by:

Edyta Madziar

2023-09-27 13:11:10